57

BÖLÜM: MÜLAKAT USTALIĞI, CANLI BEYAZ TAHTA & STAFF+ SEVIYESI | MODULE: MAANG INTERVIEW MASTERY, WHITEBOARDING & STAFF+ PLAYBOOK

Güvenlik, Kimlik ve Uyumluluk: OAuth2, mTLS, Zero-Trust ve GDPR

Security, Identity & Compliance: OAuth2, mTLS, Zero-Trust & GDPR

📐 Sistem Mimarisi & Veri Akış Şeması

📐 Architecture & Data Flow Diagram



💡 Aptala Anlatım (ELI5 Metaforu)

💡 ELI5 Metaphor

🇹🇷 TÜRKÇE (ELI5)

Eski kale modelinde kalenin etrafında derin bir su hendeği ve tek bir asma kapı vardı (Ağ Güvenlik Duvarı - Firewall). Kapıdan içeri bir kez giren casus, kalenin içindeki tüm odalara elini kolunu sallayarak girerdi! Modern Sıfır Güven (Zero-Trust) mimarisi ise şudur: Kalenin içinde bile olsanız, mutfağa girerken mutfak kapısındaki güvenlik görevlisine kimlik gösterirsiniz, kütüphaneye girerken kütüphaneciye parmak izi verirsiniz (mTLS). Kimse kimseye babasının oğlu gibi güvenmez; her oda her kapıda şifrelenir!

🇬🇧 ENGLISH (ELI5)

Legacy security relied on the 'Castle-and-Moat' model: a deep perimeter moat and a single drawbridge (Corporate Firewall). Once a hacker sneaked past the drawbridge, they roamed internal palace corridors unhindered! Modern Zero-Trust architecture abandons perimeter trust completely: Even if you sit inside the inner castle corridor, entering the kitchen requires a biometric badge, and entering the treasury requires an armed escort (Mutual TLS / mTLS). Inside a Zero-Trust network, services verify cryptographic identities for every internal hop!

🔍 MAANG Seviyesi Teknik Derinlik

🇹🇷 MAANG DERİNLEMESİNE ANALİZ

MAANG Güvenlik ve Uyumluluk Mimarisi Direkleri: 1) Zero-Trust & mTLS (Mutual TLS): 'Ağ içindekilere güven' varsayımı çökmüştür. Mikroservisler arası tüm iletişim Envoy/Istio Service Mesh üzerinden çift yönlü X.509 sertifika doğrulamasıyla (mTLS) şifrelenir. 2) OAuth 2.0 & OIDC: İstemci yetkilendirmesi için PKCE (Proof Key for Code Exchange) destekli Authorization Code Flow; servisler arası iletişim için JWT tabanlı Client Credentials. 3) GDPR ve PII (Personally Identifiable Information) Uyumluluğu: 'Unutulma Hakkı' (Right to be Forgotten) için kullanıcı verileri kriptografik olarak silinebilir (Crypto-Shredding: Kullanıcının özel şifreleme anahtarı silindiğinde veritabanındaki şifreli veri anında anlamsız çöp haline gelir). 4) Data at Rest Encryption: Veritabanı diskleri AES-256 ve AWS KMS / HashiCorp Vault anahtarlarıyla şifrelenir.

🔍 MAANG-Level Technical Deep-Dive

🇬🇧 MAANG TECHNICAL DEEP-DIVE

Enterprise Security & Compliance Framework: 1) Zero-Trust & Mutual TLS (mTLS): Eliminates internal network perimeter trust. Microservices authenticate reciprocally via X.509 certificates managed by Istio/SPIFFE, ensuring all transit traffic is cryptographically sealed with ephemeral keys. 2) Modern Identity (OAuth 2.1 & OpenID Connect): Public mobile clients employ PKCE Authorization Code flows; internal machine-to-machine transit uses short-lived JWTs signed by asymmetric public/private keys. 3) GDPR & PII Protection via Crypto-Shredding: When a user exercises their GDPR 'Right to be Forgotten', scrubbing distributed backups is nearly impossible. Instead, encrypt the user's PII with a unique per-user DEK (Data Encryption Key). Deleting the key in KMS permanently renders all historical multi-region database and backup records irreversible garbage. 4) Encryption in Transit & at Rest: Enforce TLS 1.3 across the wire and AES-256 disk volume encryption backed by Hardware Security Modules (HSM).

⚡ Modern Java 25 Uygulaması (Loom & Records)

⚡ Java 25 Implementation

```java
// Java 25: GDPR Uyumlu Kriptografik Veri Maskeleme (PII Data Masking)
public class PiiMasker {
    public static String maskEmail(String email) {
        if (email == null || !email.contains("@")) return "*****";
        var parts = email.split("@");
        String name = parts[0];
        String maskedName = name.charAt(0) + "***" + (name.length() > 1 ? name.charAt(name.length() -
1) : "");
        return maskedName + "@" + parts[1];
    }

    public static String maskCreditCard(String pan) {
        if (pan == null || pan.length() < 10) return "****";
        return "****-****-****-" + pan.substring(pan.length() - 4);
    }
}

void main() {
    String rawEmail = "aliturgutbozkurt@example.com";
    String rawCard = "4543123456789481";

    IO.println("Maskelenmiş E-posta: " + PiiMasker.maskEmail(rawEmail));
    IO.println("Maskelenmiş Kredi Kartı: " + PiiMasker.maskCreditCard(rawCard));
}
```

⚠️ Mülakat Tuzağı & Darboğaz Uyarısı

🇹🇷 MÜLAKAT TUZAĞI VE DARBOĞAZ

Mülakatta 'İç ağımız zaten güvenli, mikroservisler arasında şifreleme yapmaya gerek yok' demeyin! Modern MAANG standartlarında 'Zero-Trust' esastır; iç ağdaki her istek mTLS ile şifrelenmeli ve doğrulanmalıdır.

⚠️ Interview Trap & Bottleneck Alert

🇬🇧 INTERVIEW TRAP & BOTTLENECK

Never state that internal microservices communicate in unencrypted plain HTTP because they are 'inside the private VPC'. Staff engineers mandate Zero-Trust: all internal mesh transit must be encrypted via mTLS.

🎯 Mülakatta Hatırlanacak Altın Çıkarımlar

- Zero-Trust felsefesi ağın içindeki hiçbir servise ön koşulsuz güvenmez.
- mTLS (Karşılıklı TLS) mikroservislerin birbirini X.509 sertifikalarıyla doğrulamasını sağlar.
- Crypto-Shredding tekniği GDPR 'unutulma hakkını' dağıtık yedeklerde bile saniyede çözer.

🎯 Key Takeaways for the Interview

- Zero-Trust assumes the internal network is hostile, verifying every request cryptographically.
- Mutual TLS enforces reciprocal cryptographic authentication across service mesh pods.
- Crypto-shredding satisfies GDPR deletion by destroying user-specific encryption keys.